

Lab: SQL injection UNION attack, determining the number of columns returned by the query

1. Mục tiêu của bài lab

-Xác định số lượng cột được trả về bởi câu lệnh SQL gốc thông qua kỹ thuật UNION-based SQL Injection và việc xác định chính xác số cột là bước quan trọng để thực hiện các cuộc tấn công UNION SQL Injection ở các bước tiếp theo.

2. Trả lời câu hỏi

What is a Union-Based SQL Injection attack, and how does it differ from other types of SQL injection attacks?

→ Union-Based SQL Injection là một dạng tấn công SQL Injection sử dụng toán tử UNION để kết hợp kết quả của truy vấn do kẻ tấn công tạo ra với truy vấn hợp lệ của ứng dụng nhằm lấy dữ liệu từ cơ sở dữ liệu.

Khác với Error-Based SQL Injection (khai thác thông báo lỗi) và Blind SQL Injection (suy luận thông tin qua phản hồi của ứng dụng), Union-Based SQL Injection cho phép dữ liệu được hiển thị trực tiếp trên trang web thông qua kết quả của truy vấn UNION.

Vì vậy, đây là một trong những kỹ thuật SQL Injection nhanh và hiệu quả nhất để trích xuất dữ liệu khi ứng dụng trả về kết quả truy vấn cho người dùng.

Explain the role of the UNION SQL operator in this type of attack and how it can be used to extract data from a database that is not typically accessible through the intended use of a web application.

→ Toán tử UNION trong SQL được dùng để kết hợp kết quả của hai hoặc nhiều câu lệnh SELECT thành một tập kết quả duy nhất. Trong Union-Based SQL Injection, kẻ tấn công lợi dụng UNION để thêm một truy vấn do mình tạo ra vào truy vấn hợp lệ của ứng dụng.

Nếu số lượng cột và kiểu dữ liệu phù hợp, cơ sở dữ liệu sẽ trả về dữ liệu từ các bảng khác (ví dụ: bảng người dùng hoặc thông tin hệ thống) cùng với dữ liệu thông thường của ứng dụng. Nhờ đó, kẻ tấn công có thể truy xuất các thông tin không được thiết kế để người dùng truy cập thông qua giao diện web.

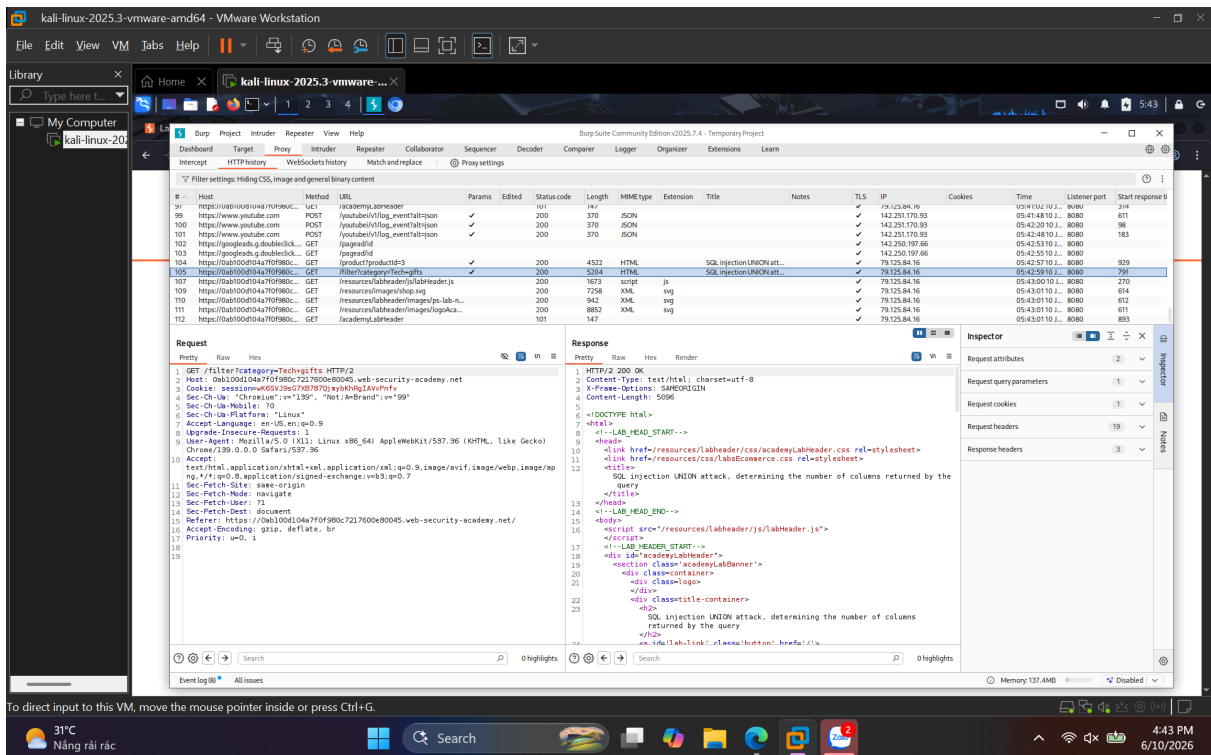
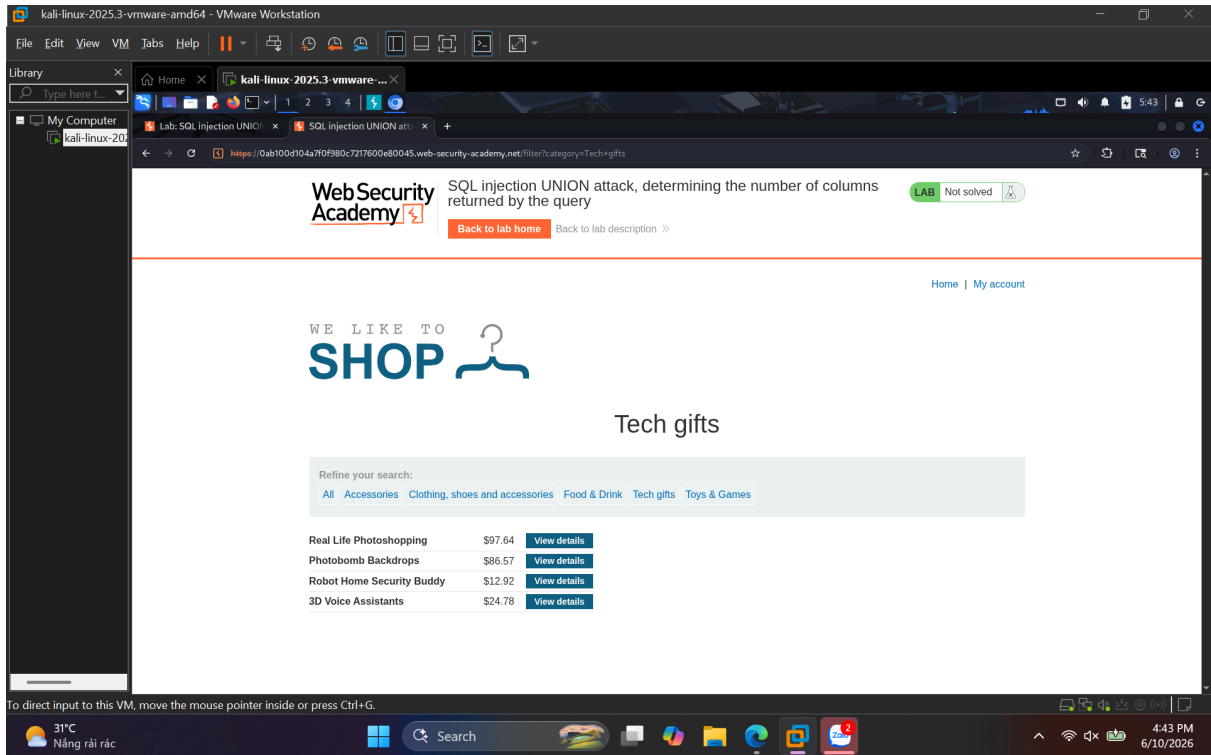
3. Chi tiết lab

B1. Chặn request bằng Burp Suite

Sử dụng Burp Suite để chặn request gửi đến server khi chọn một danh mục sản phẩm.

Request ban đầu:

GET /filter?category=Tech+gift



B2. Gửi request sang REPEATER

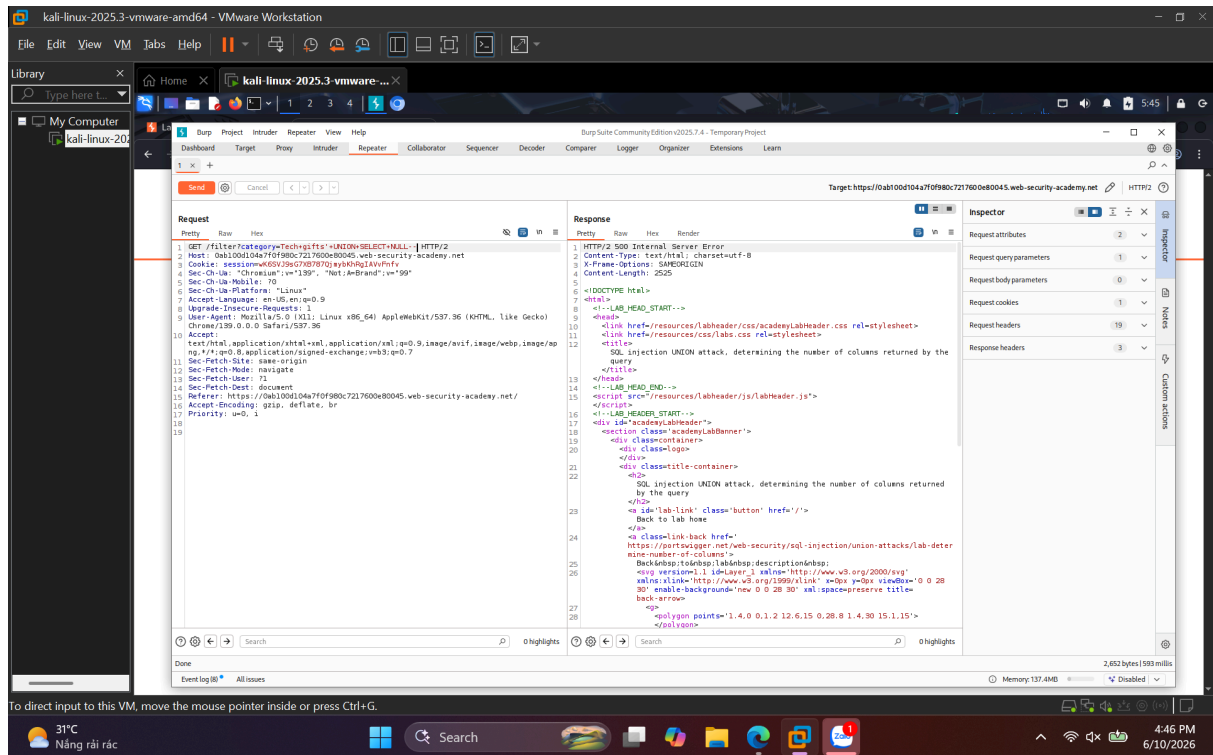
Thử UNION SELECT với một cột

Thay đổi giá trị tham số category sang:

' + UNION+SELECT+NULL--

Kết quả: Ứng dụng trả về lỗi.

Nguyên nhân là số lượng cột trong truy vấn UNION không khớp với số lượng cột của truy vấn gốc.



B3. Tăng dần số lượng cột

Tiếp tục thử các payload:

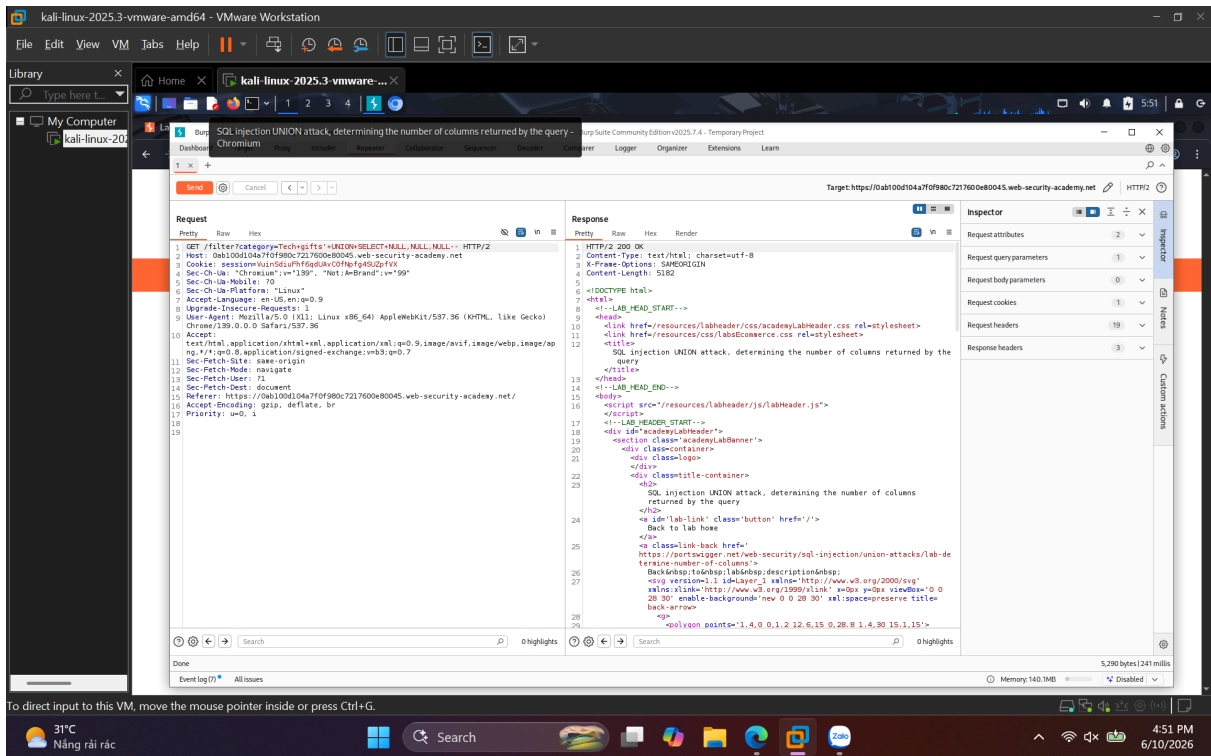
' +UNION+SELECT+NULL,NULL--

' +UNION+SELECT+NULL,NULL,NULL--

Payload thành công:

' +UNION+SELECT+NULL,NULL,NULL--

Điều này cho thấy truy vấn gốc trả về 3 cột.



B4. Trở về lab và thành công

